INFO6007

Project Management in IT

Week 07: Risk Management Plan

Semester 1, 2026

THE UNIVERSITY OF SYDNEY

Acknowledgement of Country

I would like to acknowledge the Traditional Owners of Australia and recognise their continuing connection to land, water and culture. I am currently on the land of the Gadigal people of the Eora nation and pay my respects to their Elders, past, present and emerging.

I further acknowledge the Traditional Owners of the country on which you are on and pay respects to their Elders, past, present and future.

Copyright Warning

Agenda

- Introduction
- Project Risk Management

Project Risk Management

THE UNIVERSITY OF SYDNEY

Introduction

- "A project risk is an uncertain event or condition that, if it occurs, has a positive or negative effect on one or more project objectives (such as scope, schedule, cost, or quality)."

- Risk is about **uncertainty:** something that *may or may not happen*.

- Why risk management matters in IT Projects?
  - IT projects are highly dynamic due to the rapidly changing technologies, evolving user requirements, cybersecurity concerns, data privacy concerns, etc.

Standish Group CHAOS Report

- Studies show that over 60% of IT projects fail to meet time, budget, or scope objectives. The major reason – poor risk management.

THE CHAOS REPORT

> *"The Roman bridges of antiquity were very inefficient structures.*
> *By modern standards, they used too much stone,*
> *and as a result, far too much labor to build.*
> *Over the years we have learned to build bridges more efficiently,*
> *using fewer materials and less labor to perform the same task."*
>
> -- Tom Clancy, The Sum of All Fears

INTRODUCTION

In 1986, Alfred Spector, president of Transarc Corporation, co-authored a paper comparing bridge building to software development. The premise: Bridges are normally built on-time, on-budget, and do not fall down. On the other hand, software never comes in on-time or on-budget. In addition, it always breaks down. (Nevertheless, bridge building did not always have such a stellar record. Many bridge building projects overshot their estimates, time frames, and some even fell down.)

One of the biggest reasons bridges come in on-time, on-budget and do not fall down is because of the extreme detail of design. The design is frozen and the contractor has little flexibility in changing the specifications. However, in today's fast moving business environment, a frozen design does not accommodate changes in the business practices. Therefore a more flexible model must be used. This could be and has been used as a rationale for development failure.

But there is another difference between software failures and bridge failures, beside 3,000 years of experience. When a bridge falls down, it is investigated and a report is written on the cause of the failure. This is not so in the computer industry where failures are covered up, ignored, and/or rationalized. As a result, we keep making the same mistakes over and over again.

Consequently the focus of this latest research project at The Standish Group has been to identify:

The scope of software project failures

The major factors that cause software projects to fail

The key ingredients that can reduce project failures

Risk management in IT Project Management

- The main goals of Risk management are:
  - Identify potential risks early.
  - Assess their probability and impact.
  - Develop strategies to minimize threats and maximize opportunities.
  - Monitor risks throughout the project lifecycle.
  - Enable informed decision-making under uncertainty.

- Risk management is an integral part of IT Project management:
  - It’s not a one-time task → continuous process across the project lifecycle.
  - Risk management complements other PM processes (scope, schedule, cost, quality).
  - Helps project managers avoid “firefighting mode” and focus on proactive planning.

Types of Risks

- Risks are **not always bad.** They can be **threats (negative risks)** or **opportunities (positive risks)**. Both need to be managed with a structured process.

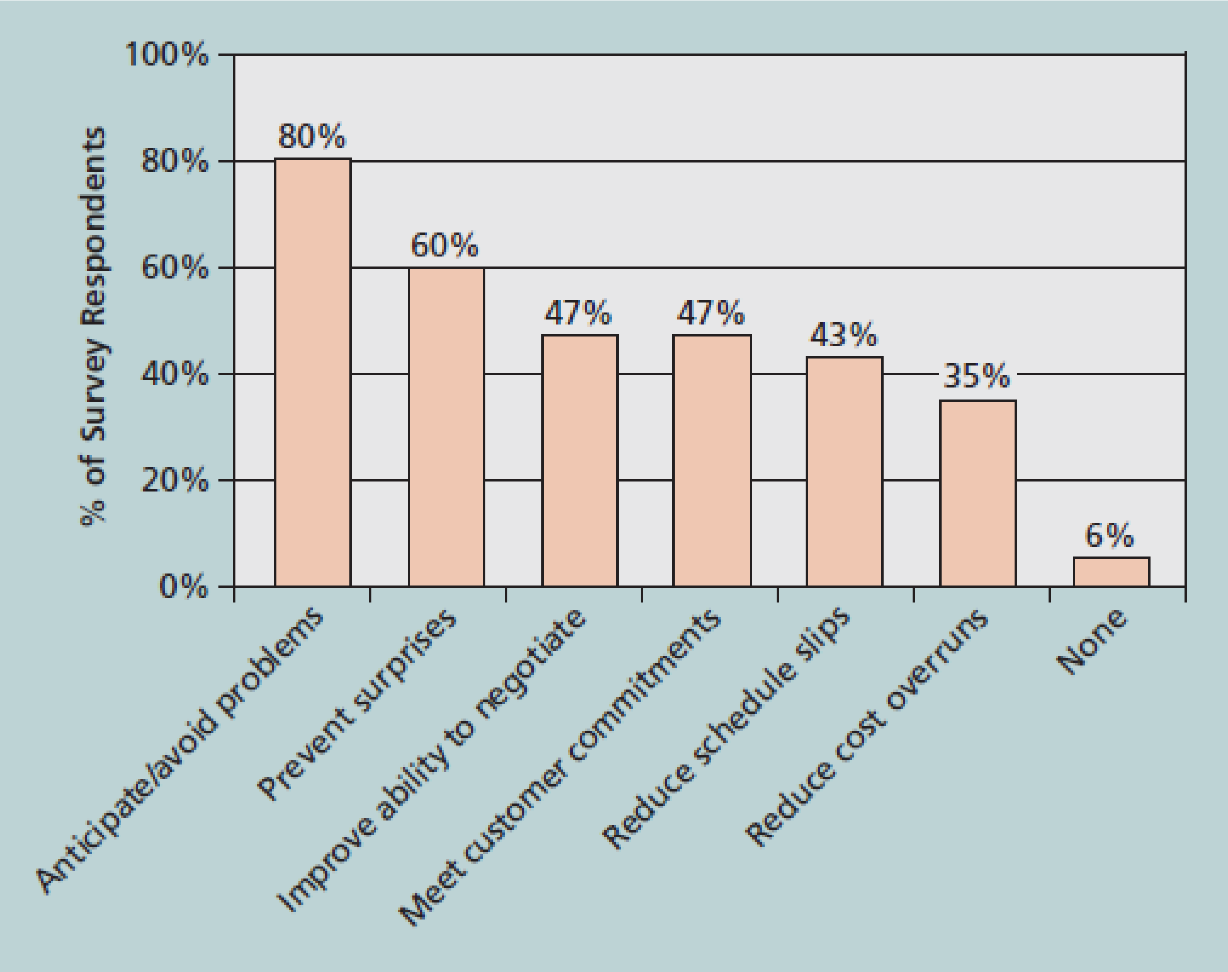
Aspect	Positive Risks	Negative Risks
Context	These are opportunities	These are threats
Definition	Events that, if they occur, have a beneficial effect on project objectives.	Events that, if they occur, have a harmful effect on project objectives.
Impact	Beneficial for the project	Harmful for the project
Management Approach	Exploit, enhance, share, or accept.	Avoid, mitigate, transfer, or accept.

Categories of Risk

- Market risk
  - Risks that arise from changes in external market conditions.
- Financial risk
  - Risks related to project funding, budget, and cost overruns.
- Technology risk
  - Risks associated with the adoption, integration, or performance of technology.
- People risk
  - Risks that arise from human factors, resource management, and stakeholder involvement.
- Structure/Process risk
  - Risks related to organizational processes, governance, and project structures.

Benefits of Risk Management

- Improved Project success rate
- Better decision making
- Cost and time savings
- Increased stakeholder confidence
- Competitive advantage
- Compliance and Governance



Source: Kulik and Weber, KLCI Research Group

FIGURE 11-1 Benefits from software risk management practices

Risk Communication

- It is the process of **sharing information about risks** (both threats and opportunities) with project stakeholders in a clear, timely, and transparent manner.

- The main objectives of risk communication are:
  - Ensure stakeholders understand risks and their impact.
  - Provide updates on risk status, responses, and changes.
  - Build trust between project teams, management, and clients.
  - Support informed decision-making on risk responses.

Stakeholder engagement in Risk Management

- It is necessary to involve stakeholders throughout the risk management cycle to ensure buy-in and support.

- It is necessary as:
  - Stakeholders may identify risks unknown to the project team.
  - Improves accuracy of risk assessments (probability/impact).
  - Builds shared ownership of risks and responses.
  - Reduces resistance to change by involving them early.

- It is necessary to have effective risk communication. This can be achieved through being clear, consistent, timely, transparent, and action oriented.

Example: UK NHS National Programme for IT

- The **UK National Health Service (NHS)** launched the **National Programme for IT (NPfIT)** in 2002.
  - Goal: Create a nationwide electronic patient records system, improve healthcare IT infrastructure, and standardize systems across the NHS.
  - Budget: ~£12 billion (one of the largest IT projects in Europe).

- Risks identified:
  - Technology Risks: Integration of multiple vendors and legacy systems.
  - People Risks: Clinician resistance to adopting new workflows.
  - Financial Risks: Massive budget overruns.
  - Process Risks: Inconsistent governance across NHS regions.

Example: UK NHS National Programme for IT

- Risk communication challenges:
  - Risks were communicated mostly among senior leadership, but frontline staff (clinicians, nurses, admin staff) were left out.
  - Vendors and project managers often downplayed risks to avoid political fallout. This led to **delayed decision-making** and unaddressed risks snowballing.
  - Parliament and the public were not given accurate updates on risks, creating reputational damage when failures emerged.
- Stakeholder engagement issues:
  - Clinicians: Not engaged early in the risk identification process → felt systems didn't match medical workflows.
  - Vendors: Misaligned incentives → suppliers focused on meeting contract milestones, not long-term risk mitigation.
  - Government/Parliament: Involved too late, mainly during crisis moments.

Example: UK NHS National Programme for IT

- Outcome:
  - The programme was **ultimately abandoned** in 2011 after billions were spent, with most objectives unfulfilled.
  - One of the biggest lessons cited: “Failure to effectively communicate risks and engage stakeholders at all levels of the NHS.”

- Key lessons:
  - Engage all stakeholders early – especially end-users who will live with the system.
  - Communicate risks openly and continuously – hiding risks erodes trust.
  - Tailor risk communication – senior leaders need summaries, technical teams need detailed logs, end-users need practical guidance.
  - Transparency builds resilience – it’s better to face short-term criticism than long-term project collapse.

Risk Appetite

- It is defined as the **degree of uncertainty an organisation is willing to accept** in pursuit of its objectives.

- Some organisations are **risk-seeking** (take bold moves to innovate) whereas some are **risk-averse** (prioritise stability and predictability).

- Key factors which influence Risk appetite are:
  - **Industry context:** e.g., tech startups often have higher risk appetite than government agencies.
  - **Financial health:** companies with strong reserves may tolerate more risk.
  - **Leadership mindset:** risk-taking vs. conservative decision-making.
  - **Stakeholder expectations:** e.g., shareholders may demand high growth (higher risk appetite).

Risk appetite and Organisational culture

- Organisational culture can be defined as the **shared values, beliefs, and behaviors** that shape how risk is perceived and managed within an organisation.

- There are mainly 3 types of organisational cultures in terms of risk:
  - **Risk-Averse Culture:** avoids uncertainty, prefers compliance, detailed approvals, slow to innovate.
  - **Risk-Neutral Culture:** balances opportunities and threats pragmatically.
  - **Risk-Seeking Culture:** encourages experimentation, innovation, rapid scaling.

- Alignment is crucial: If risk appetite doesn't match the actual organisational culture, risk management fails.

Risk utility functions and risk preference

- A **risk utility function** represents how much **value (utility)** a person or organization assigns to potential outcomes under uncertainty.
- This helps project managers and stakeholders **make choices** when faced with risks.

- Stakeholders differ in how they evaluate risks:
  - Risk averse: Prefer to avoid uncertainty, will choose a **certain but lower payoff** over a risky higher payoff.
  - Risk seeking: Prefer risk, willing to take chances for a potentially higher payoff.
  - Risk neutral: Indifferent to risk, focus only on **expected monetary value (EMV)**.

Risk utility functions and risk preference

- X-axis: Monetary value (or project benefit).
- Y-axis: Utility (satisfaction or value derived).

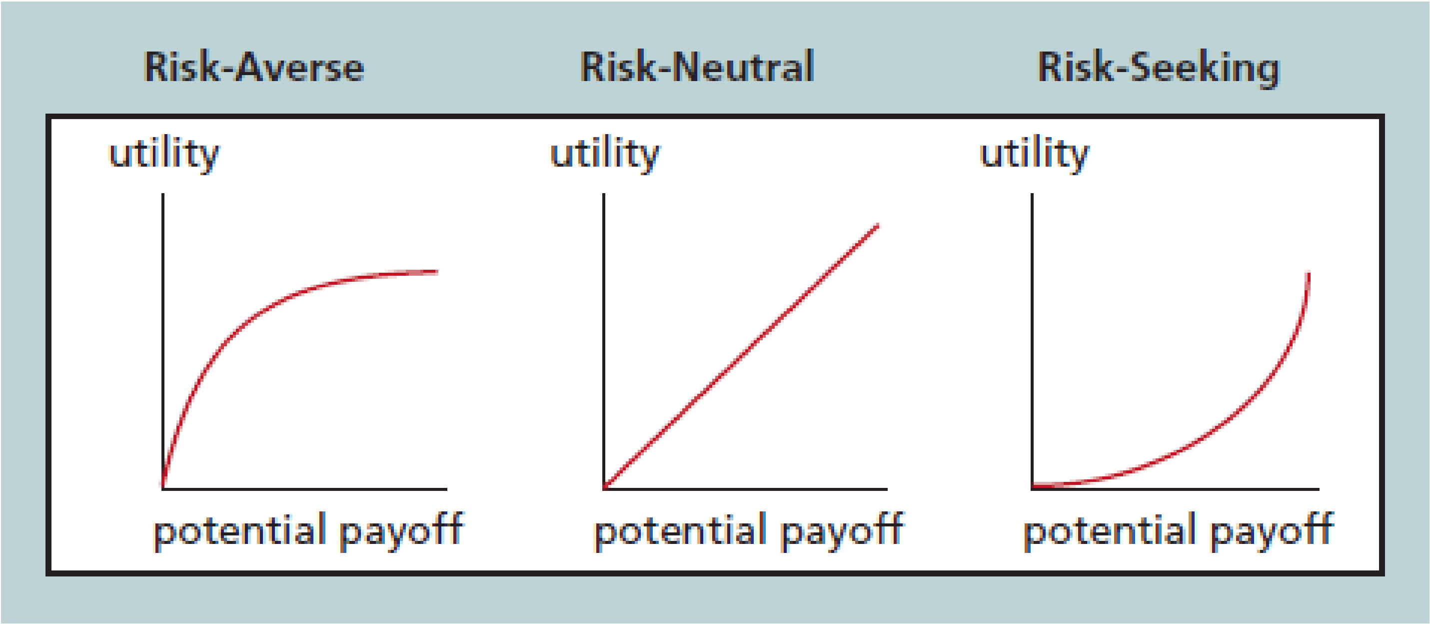


FIGURE 11-2 Risk utility function and risk preference

Menti – A Risky Business!

- A small startup developing an AI-powered fitness app faced is looking for a global launch with only a 20% chance of success but a potential $5M payoff. The CEO chose the global launch.
  - What do you think of the risk preference of this company?
  - https://www.menti.com/alpotyuuej1w

The 6 processes of Risk Management in IT

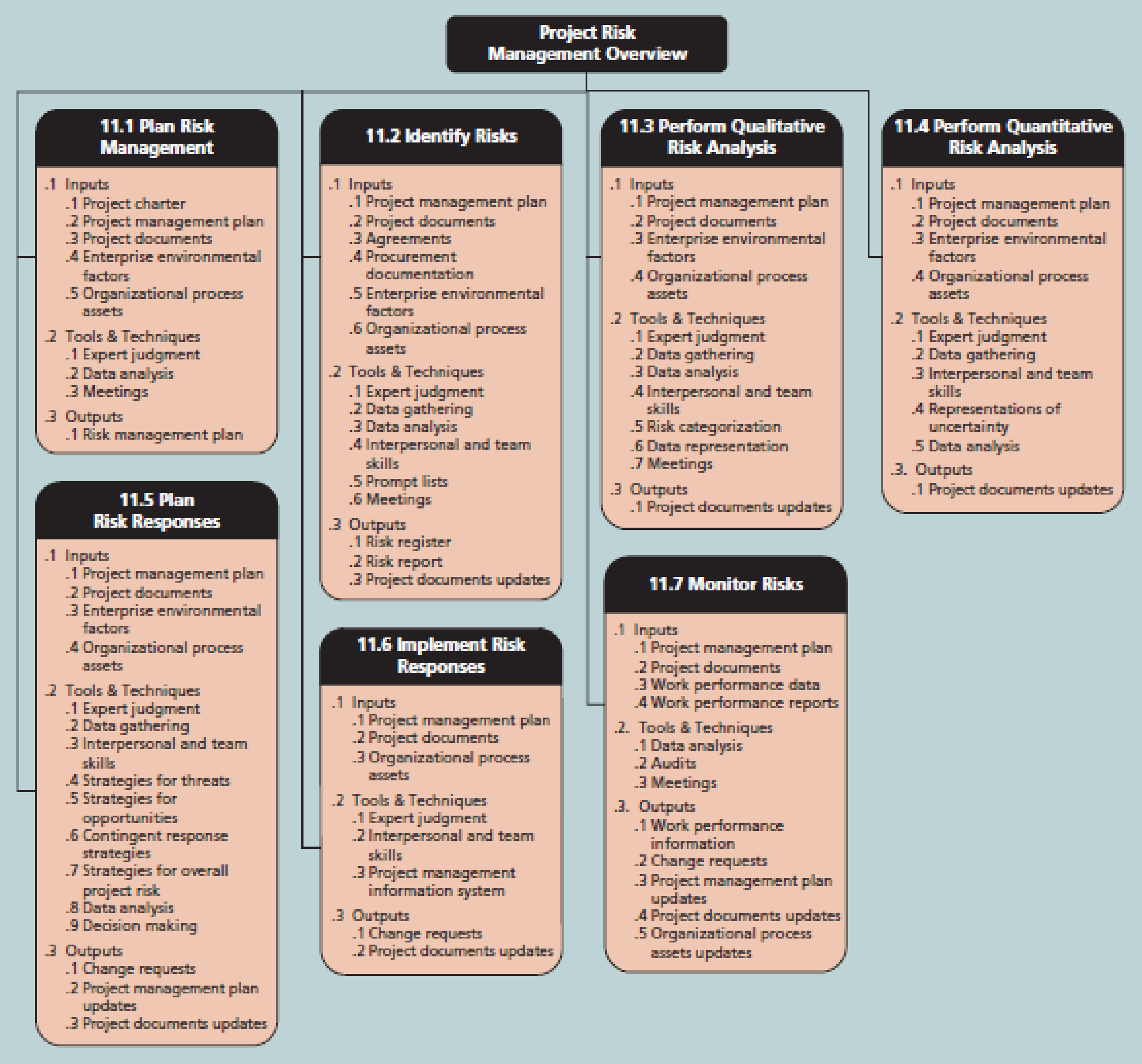


FIGURE 11-3 Project risk management overview

1. Plan Risk Management

- It is the **first step** in the risk management process.
- The main purpose of this step is to define *how* to conduct risk management activities for a project.

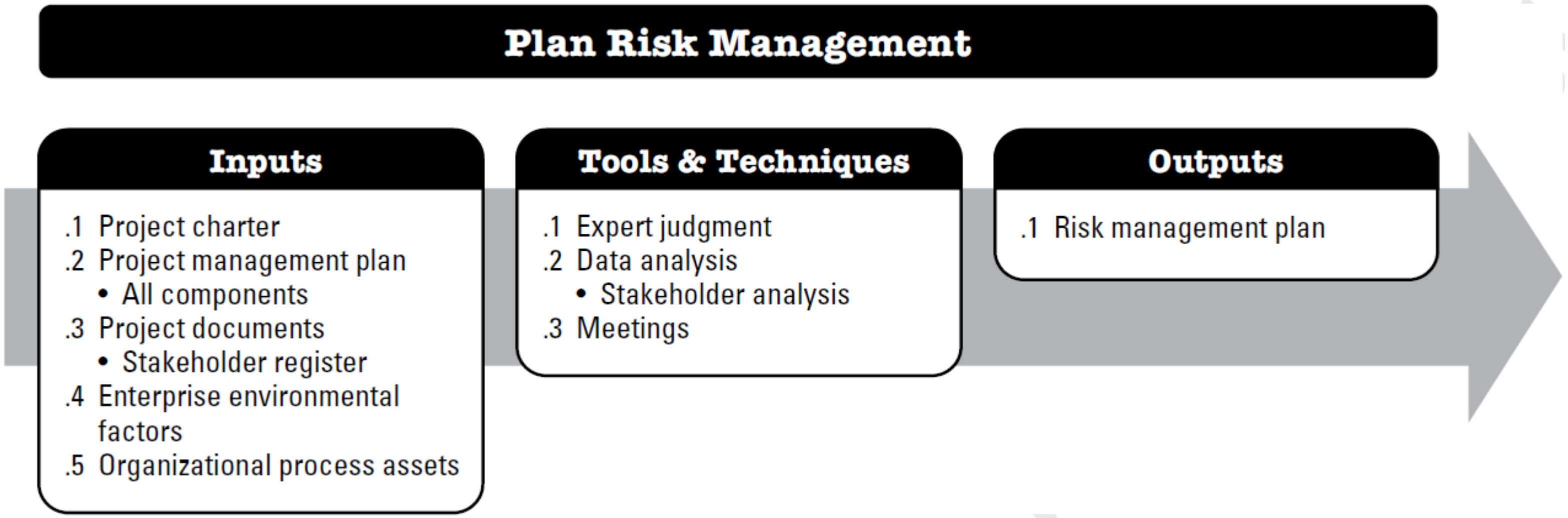


Figure 11-2. Plan Risk Management: Inputs, Tools & Techniques, and Outputs

(Project Risk Management, 2025)

Planning in risk management

- The main objectives of planning risk management:
  - Ensure risk management is **structured, consistent, and cost-effective**.
  - Define roles & responsibilities (who manages risks, who approves responses).
  - Establish methods, tools, and techniques (e.g., brainstorming, Monte Carlo).
  - Allocate resources (budget, time, risk reserves).
  - Set thresholds (what level of risk is acceptable).

- Benefits of proper planning
  - Risks are managed **proactively, not reactively.**
  - Provides transparency for stakeholders.
  - Saves time/cost by reducing surprises.
  - Builds team alignment on priorities.

2. Identify Risks

- This step refers to the process of **determining which risks may affect the project** and documenting their characteristics.
- The main goal is to create an initial **Risk Register**.

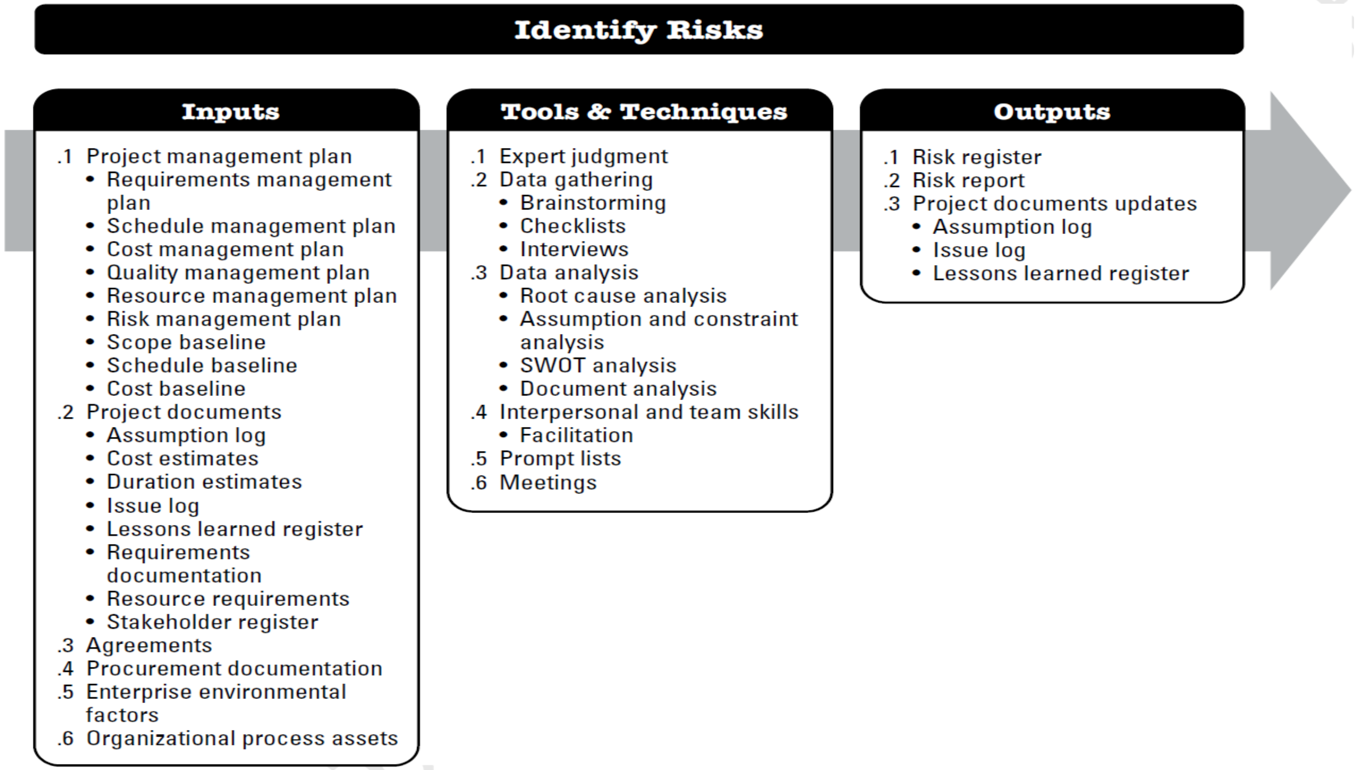


Figure 11-6. Identify Risks: Inputs, Tools & Techniques, and Outputs

(Project Risk Management, 2025)

THE UNIVERSITY OF SYDNEY

Identifying risks

- Conducted early in the project, continues throughout the lifecycle.
- This process helps avoid being blindsided by threats or missing opportunities.
- It is a proactive way to manage uncertainty rather than reacting later.

- At the end of this process, you would be able to create a Risk Breakdown Structure

Risk Breakdown Structure

- It is a **hierarchical representation** of risk categories.
- Helps systematically think through all possible risk sources.

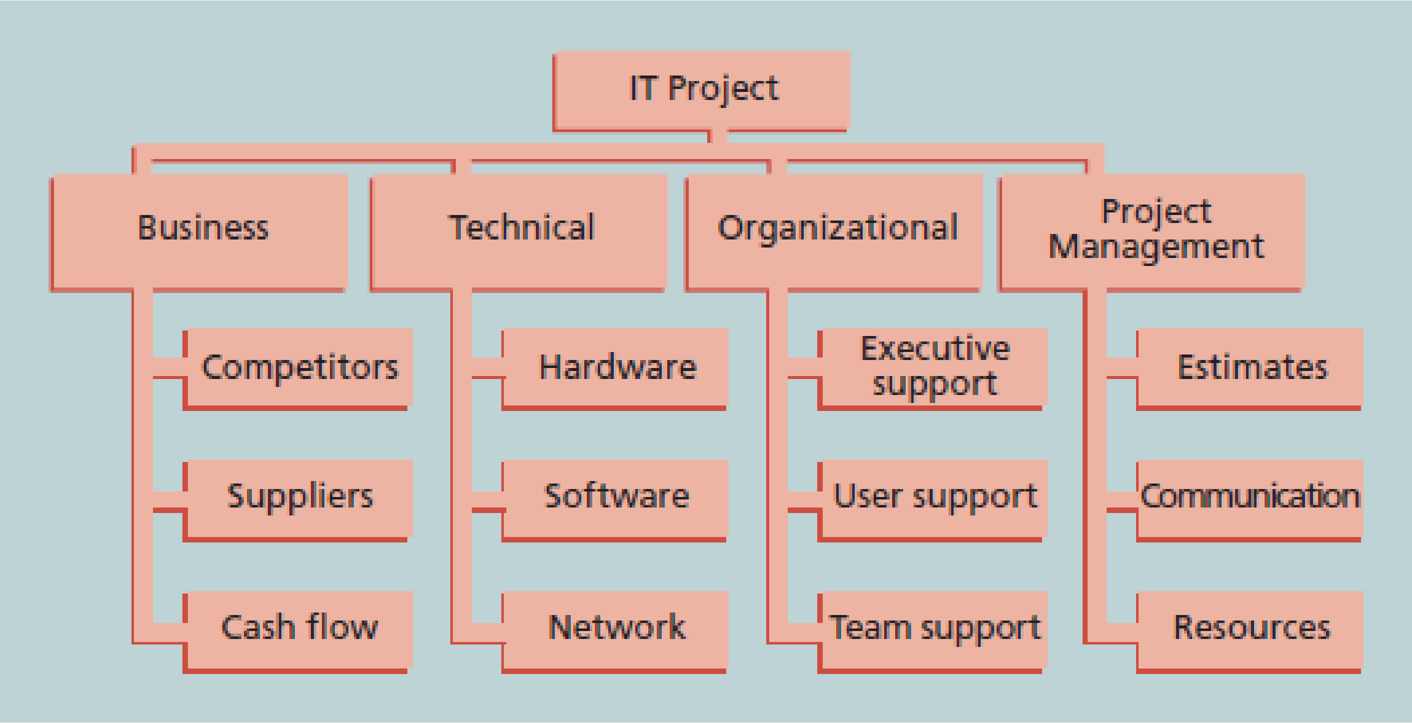


FIGURE 11-4 Sample risk breakdown structure

Risk Identification tools and techniques - Brainstorming

- This is a group creativity technique where team members generate a large number of risk ideas in a free-flowing, non-judgmental environment.

- Advantages
  - Quick, easy, encourages diverse perspectives.
  - Good for early-stage projects with high uncertainty.
- Disadvantages
  - May be dominated by louder voices.
  - Quality depends on facilitator skill.

Risk Identification tools and techniques – The Delphi technique

- A structured method of obtaining consensus from a panel of experts through **multiple rounds of anonymous surveys**.

- Advantages
  - Avoids influence of dominant personalities.
  - Effective for complex, uncertain projects requiring expert judgment.
- Disadvantages
  - Time-consuming (multiple rounds).
  - Relies on availability of true experts.

Risk Identification tools and techniques - Interviewing

- Gathering risk information by conducting structured or unstructured interviews with stakeholders, subject matter experts (SMEs), or experienced team members.

- Advantages
  - Provides deep insights and context.
  - Useful for uncovering risks not obvious to the broader team.
- Disadvantages
  - Can be subjective.
  - Risk of interviewer bias or incomplete information.

Risk Identification tools and techniques – SWOT Analysis

- A strategic tool used to assess internal strengths & weaknesses, and external opportunities & threats. It can be adapted to identify both **positive and negative risks**.

- Advantages
  - Easy to use, covers both internal and external factors.
  - Balances positive and negative risks.
- Disadvantages
  - Can oversimplify complex risks.
  - Output quality depends on participants' knowledge.

3. Perform Qualitative Risk Analysis

- A **subjective** method of prioritizing risks based on their **probability of occurrence** and **impact on objectives**.
- Helps project managers **focus on the most significant risks** early on.
- Conducted after risk identification, before quantitative analysis.
- Uses expert judgment, risk categorization, and qualitative tools.

- The main objectives of this step are:
  - Prioritize risks for further analysis or action.
  - Assign **relative importance** to each risk.
  - Provide input for **risk response** planning.
  - Ensure stakeholders are aligned on risk severity.

Probability and Impact Assessment

- A technique used for qualitative risk analysis.

- In this assessment, each risk is rated for:
  - Likelihood (For example: Low, Medium, High)
  - Impact (on cost, time, scope, quality)

Risk Matrix			Impact Severity				
			0	0.2	0.5	0.7	0.9
			Insignificant	Minor	Moderate	Major	Catastrophic
Risk Likelihood	90%	Almost Certain					
	65%	Likely					
	40%	Possible					
	20%	Unlikely					
	0%	Rare					

Risk Grade	Recommended Management Approach
Extreme	Immediate treatment required
High	Raise to management attention
Moderate	Identify treatment strategies and assign responsibility
Low	Monitor through routine process

THE UNIVERSITY OF SYDNEY

Probability Impact Matrix

- A grid mapping **probability** vs. **impact**.
- Helps categorize risks into **High / Medium / Low priorities**.

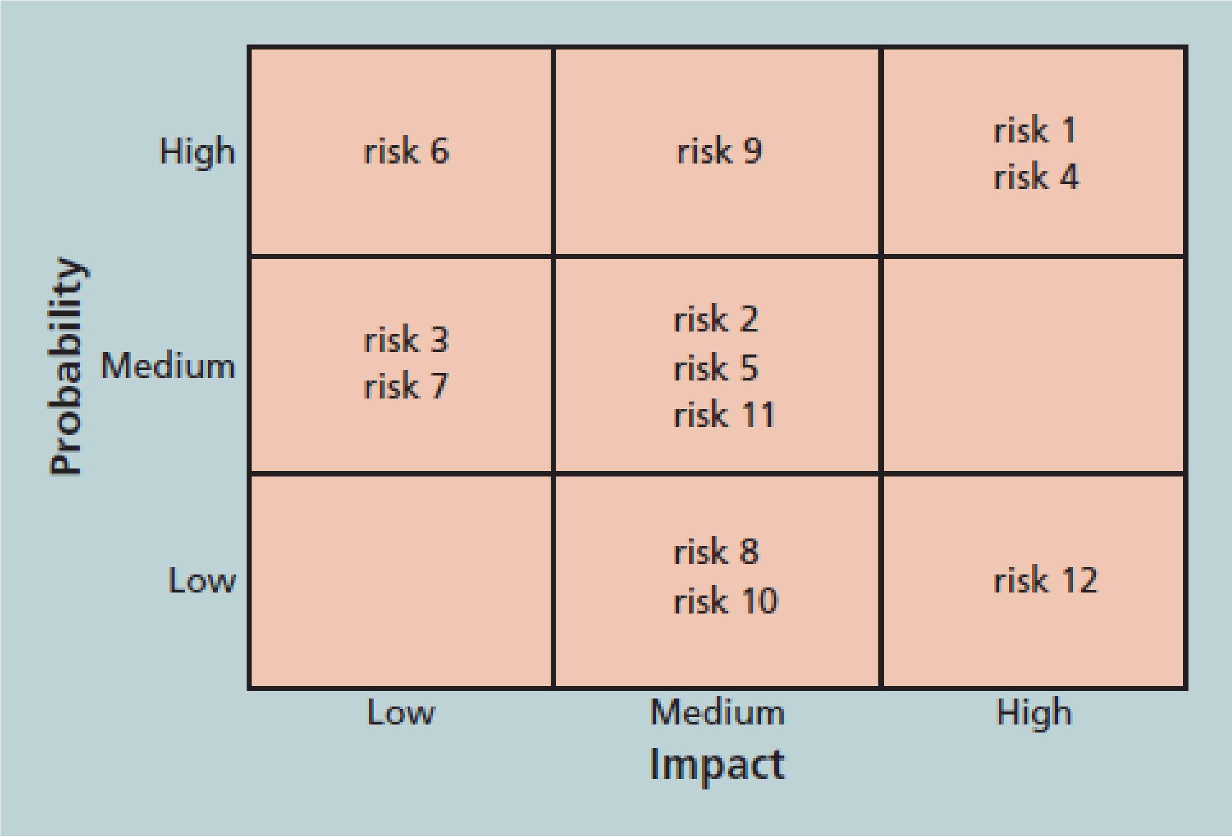


FIGURE 11-5 Sample probability/impact matrix

4. Perform Quantitative Risk Analysis

- A **numerical, data-driven process** of analyzing the **effect of risks on overall project objectives** (cost, schedule, scope, quality).
- Unlike qualitative analysis (subjective prioritization), **quantitative analysis uses models, simulations, and statistics**.
- This step helps determine:
  - Probability of meeting deadlines.
  - Expected cost overruns.
  - Overall risk exposure of the project.
- The main objectives of this step are:
  - Measure the **combined effect of individual risks** on project objectives.
  - Determine **probabilities of success or failure**
  - Support decision-making on contingency reserves, budget, and schedule buffers.
  - Prioritize risks that have the greatest impact quantitatively.

Monte Carlo Simulation

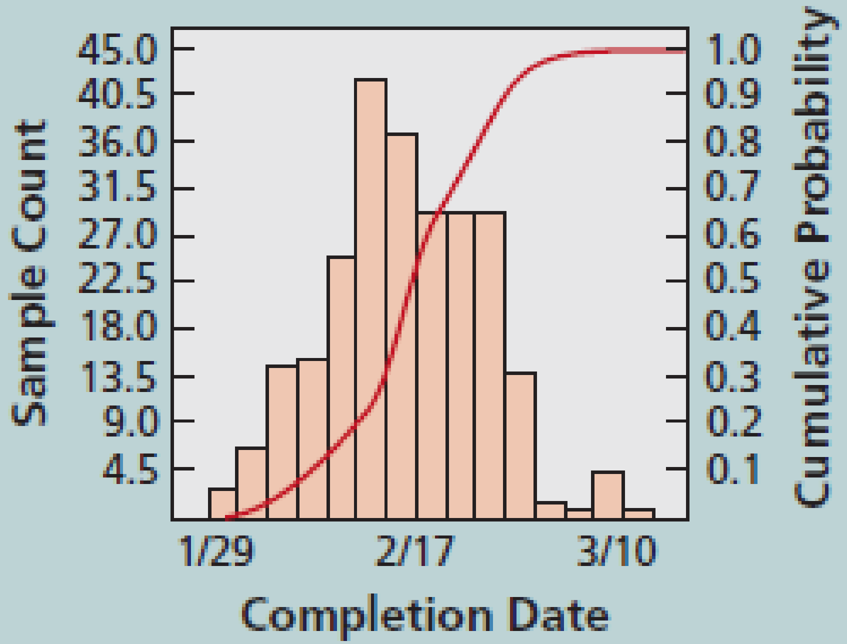
- A **probabilistic technique** that uses random sampling to simulate different possible outcomes of a project.
- It runs **thousands of iterations** with varying inputs (time, cost, risk impact).
- It produces a **range of possible outcomes** instead of a single estimate.

- How to do the Monte Carlo Simulation?
  - Define variables
    - Identify uncertain factors (e.g., task durations, costs) and assign probability distributions (Normal, Triangular, Beta, etc.)
  - Run simulations
    - Software randomly selects values within the distributions. The software runs the project schedule/cost model thousands of times.
  - Analyse results

Monte Carlo Analysis

Date: 1/14   11:13:56 AM
Number of Samples: 250
Unique ID: 1
Name: Widget

Completion Std Deviation: 5.2 days
95% Confidence Interval: 0.6 day
Each bar represents 2 days.



Completion Probability Table

Prob	Date	Prob	Date
0.05	2/4	0.55	2/17
0.10	2/8	0.60	2/18
0.15	2/9	0.65	2/19
0.20	2/10	0.70	2/22
0.25	2/11	0.75	2/22
0.30	2/12	0.80	2/23
0.35	2/15	0.85	2/24
0.40	2/15	0.90	2/25
0.45	2/16	0.95	2/26
0.50	2/17	1.00	3/10

FIGURE 11-8 Sample Monte Carlo–based simulation results for project schedule

Decision Tree Analysis

- A **visual and analytical tool** to evaluate choices when facing uncertain outcomes.
- Combines **decision branches (choices)** and **chance branches (risks/probabilities)**.
- Used to calculate **Expected Monetary Value (EMV)**.

- Steps in DTA
  - Identify the decision point (e.g., outsource vs. develop in-house).
  - List alternatives (branches of the tree).
  - Attach probabilities to each possible outcome.
  - Assign payoffs/costs to outcomes.
  - **Calculate EMV** for each decision branch:
  - **Select the decision with the highest EMV**.

THE UNIVERSITY OF SYDNEY

Decision Tree Analysis - Example

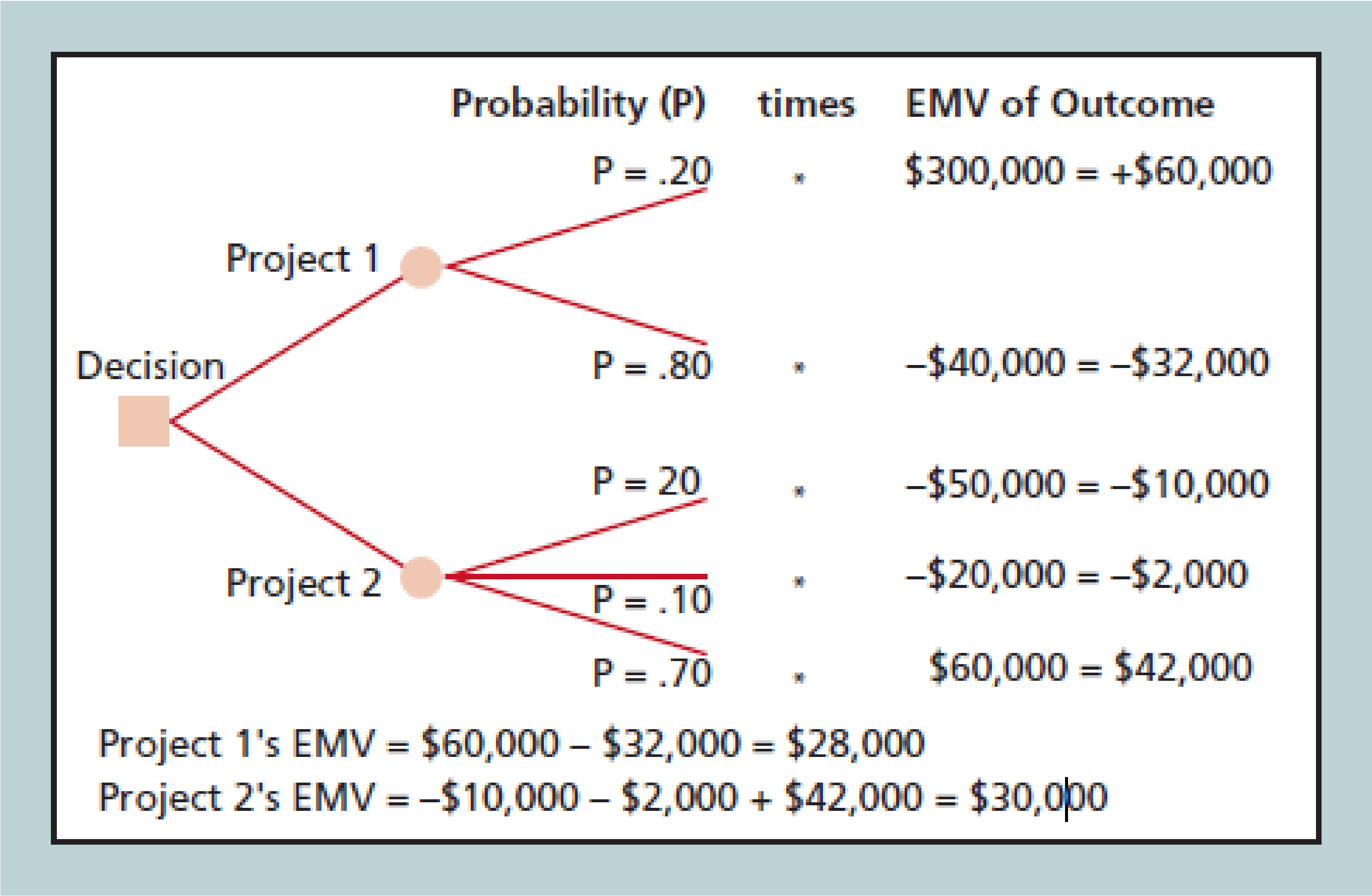


FIGURE 11-7 Expected monetary value (EMV) example

5. Plan Risk Responses

- The process of developing **options, strategies, and actions** to address identified risks.
- Ensures that opportunities are maximized and threats are minimized.
- It is a proactive step, deciding what to do before the risk occurs!

- The main objectives:
  - Reduce threats to project objectives (cost, time, scope, quality).
  - Enhance opportunities for success.
  - Assign **risk owners** responsible for monitoring & executing responses.
  - Ensure response actions are **cost-effective** and realistic.

Risk Responses for Negative risks (Threats)

- Avoidance
  - Eliminate the threat entirely.
  - Example: Change project scope to exclude high-risk functionality.
- Mitigation
  - Reduce probability or impact.
  - Example: Conduct extra testing to reduce risk of software failure.
- Transfer (Transference)
  - Shift responsibility to a third party.
  - Example: Buy insurance, outsource to vendor with SLA guarantees.
- Acceptance
  - Do nothing proactively; accept consequences if risk occurs.
- Escalation
  - When risk is outside project scope → escalate to program/portfolio management.
  - Example: Company-wide cybersecurity risk.

Risk responses for Positive risks

- Exploitation
  - Ensure the opportunity happens.
  - Example: Assign best resources to a task to guarantee early completion.
- Enhancement
  - Increase probability or impact.
  - Example: Provide team training to improve productivity.
- Sharing
  - Partner with a third party to capture the benefit.
  - Example: Collaborate with another firm for joint product launch.
- Acceptance
  - Take advantage if opportunity arises but don’t actively pursue it.
  - Example: Use extra developer hours only if available.
- Escalation
  - When opportunity is beyond project scope → escalate to higher authority.

Risk Register

- It is a **central document** in risk management that records all identified risks, their characteristics, and planned responses.
- Acts as a **living document**: updated throughout the project lifecycle.
- It ensures risks are **visible, monitored, and assigned owners**.

- The main purpose of a risk register is to:
  - Provide a structured way to capture, track, and communicate risks.
  - Ensure accountability (each risk has an owner).
  - Serve as a decision-making tool for prioritizing and planning responses.

Risk Register

TABLE 11-4 Sample risk register

No.	Rank	Risk	Description	Category	Root Cause	Triggers	Potential Responses	Risk Owner	Probability	Impact	Status
R44	1										
R21	2										
R7	3										

6. Monitor and Control Risks

- It is the process of **tracking identified risks, monitoring residual risks, identifying new risks, and evaluating risk process effectiveness**.
- Ensures the risk management plan remains **relevant and effective**.
- Happens **throughout the project**, not just once.

Traditional vs Agile approach to Risk

- **Traditional (Waterfall)**: Risks are identified, analyzed, and planned upfront during project initiation and planning. Risk register + formal reviews are created.

- **Agile**: Risks are addressed **iteratively** throughout the project in short cycles (sprints/iterations). Risk management is **embedded in daily activities**, not just upfront.

- **Hybrid**: Combines structured **traditional risk processes** (register, probability-impact matrix) with **Agile practices** (daily monitoring, adaptive responses).

Agile Risk Management Practices

- **Iterative Risk Reviews**
  - Risks are revisited at the end of every sprint (retrospectives).
  - Early detection through continuous delivery → reduces uncertainty.
- **Risk-Based Backlog Prioritization**
  - User stories and features with higher uncertainty/risk are delivered earlier ("fail fast" principle).
  - Example: Testing a new cloud service early to uncover integration risks.
- **Risk Burn-Down Charts**
  - Similar to sprint burn-down charts but track **risk exposure over time**.
  - Helps visualize whether overall project risk is increasing or decreasing.
- **Collaborative Ownership**
  - Risks are not managed by a single "risk manager" but shared among the team.
  - Encourages **cross-functional visibility**.

THE UNIVERSITY OF SYDNEY

Advantages of Agile/Hybrid Risk management

- **Agile**:
  - Faster risk detection.
  - Better stakeholder involvement (constant feedback).
  - Adaptability to changing requirements.

- **Hybrid**:
  - Balances flexibility with formal governance.
  - Suited for large IT projects with multiple stakeholders, regulators, and vendors.

References

- Schwalbe, K., 2018. Project Risk Management. In: *Information Technology Project Management.* Boston: Cengage, pp. 463-503.

- Aldridge, E. (2025). *Understanding the Monte Carlo Analysis in Project Management*. Retrieved from Project Management Academy: https://projectmanagementacademy.net/resources/blog/understanding-the-monte-carlo-analysis-in-project-management/

- *Project Risk Management*. (2025). Retrieved from Project Engineer: https://www.projectengineer.net/tutorials/pmp-exam-tutorial/project-risk-management/

For You!

THE UNIVERSITY OF SYDNEY

End of Lecture Questions

- What is the difference between a positive and a negative risk? Provide one IT-related example for each.

- Explain the difference between qualitative and quantitative risk analysis.

- What are the four main strategies for responding to negative risks?

- How does a risk register help in project decision-making?

- Explain how risk escalation differs from risk transfer.

Case Study

- A mid-sized financial services company is migrating its legacy systems to a **cloud-based infrastructure**. The project involves multiple vendors, internal development teams, and strict compliance requirements due to handling sensitive customer data.
- Identified risks:
    - Vendor A may delay delivery of cloud migration tools.
    - A new government regulation on customer data storage may come into effect during the project.
    - There is a 25% chance of data loss during migration if proper backup measures are not in place.
    - One of the senior developers is highly skilled but is considering leaving the company.
    - The company discovered that by adopting AI-powered monitoring tools, they could improve system uptime and reduce post-migration costs.

Case-study based questions

- Classify each of the five risks above as **negative risk** or **positive risk**.
- Assign each risk to a **risk category** (Market, Financial, Technology, People, Structure/Process).
- If the potential data loss (Risk 3) could cost $200,000, calculate the **Expected Monetary Value (EMV)** of this risk.
- What contingency or fallback plan would you recommend for Risk 4 (developer leaving)?

THE UNIVERSITY OF SYDNEY

THE UNIVERSITY OF SYDNEY